

Semantic Secrets: Privacy-Preserving Authentication from AI-Generated Images

Research-Direction Draft for PETS/PoPETs 2027

Author Name
Institution Name
author@email.com

Working Draft – August 2026

Abstract

Passwords require users to reproduce exact strings even though human memory is naturally tolerant to semantic variation. This project investigates a different authentication primitive: a *semantic credential* represented through an AI-generated image. During enrolment, a user describes a visual concept, a local generative model renders an image, and a local semantic extractor converts the image into a canonical representation of objects, attributes, counts, and relations. During authentication, the user recreates the concept, a new image is generated independently, and the system determines whether the new semantic representation belongs to an authorised acceptance region around the enrolled credential.

The research is not intended to claim that AI-generated images are inherently more memorable or higher entropy than passwords. Instead, it studies the security and privacy consequences of using noisy semantic secrets for authentication. The central technical problem is that approximate matching improves tolerance to variation while simultaneously enlarging the set of guesses that an attacker can submit successfully. Moreover, a naively stored semantic representation may become an offline verifier after server compromise and may leak sensitive information about the user’s secret. The target contribution is therefore a privacy-preserving authentication protocol that supports approximate semantic matching while minimising disclosure of the semantic credential and reducing the usefulness of a compromised authentication database.

The project will build an end-to-end prototype, compare structured semantic representations and embedding-based baselines, investigate OPRF/PSI-style private set matching, fuzzy-extractor/PAKE alternatives, and encrypted similarity computation, and evaluate security, privacy, reliability, and performance without recruiting human participants. Human memorability and usability are explicitly outside the scope of this paper and are reserved for future studies.

1 Motivation and Research Direction

Users frequently choose weak or reused passwords because exact high-entropy strings are difficult to recall. Password managers mitigate this problem but introduce a dependency on an additional application, device, or service. Graphical passwords and biometric authentication provide alternative interfaces, but many constructions remain tied to exact images or store templates that can become sensitive long-lived identifiers.

This project studies whether a secret can instead be represented by the *semantic content* of a visual concept. The user should not need to reproduce identical pixels. For example, an enrolled concept might correspond to:

“a black cat wearing a yellow astronaut helmet while riding a bicycle on the moon.”

Two independent image generations of this concept can differ substantially in colour, composition, pose, and texture while preserving important semantic elements. The system therefore authenticates semantic equivalence rather than pixel equality.

The research direction is intentionally different from a generic “AI graphical password” proposal. The main question is not whether an AI model can generate an image. The main question is whether a noisy semantic secret can be authenticated *privately* when the server should learn as little as possible about that secret and when a database compromise should not trivially create a reusable offline guessing oracle.

This privacy focus is essential for a PoPETs/PETS submission. The final paper must demonstrate a concrete connection to real-world privacy applications, not merely use privacy as an application label. The prototype and evaluation must therefore make protection of the semantic credential, resistance to server/database compromise, and cross-service unlinkability first-class design goals.

1.1 Central research question

The project is organised around the following main research question:

Can noisy semantic concepts reproduced through independently generated images be used for authentication while preventing the authentication service, a database attacker, or an AI-assisted guesser from learning or efficiently validating the underlying semantic secret?

The research should answer this question through a combination of protocol design, implementation, security analysis, empirical attack evaluation, and performance measurements.

2 Scope and Non-Goals

2.1 In scope

The paper will study:

- semantic credential construction from AI-generated images;
- reproducibility of semantic representations across independent generations;
- approximate authentication and its security–reliability trade-off;
- privacy-preserving storage and comparison of semantic credentials;
- resistance to online and offline semantic guessing attacks;
- AI-assisted attack strategies using language and image-generation models;
- privacy leakage from stored records and semantic representations;
- cross-service linkability;
- robustness to changes in image-generation and semantic-extraction models;
- computational, communication, storage, and latency overhead; and
- reproducibility through an open implementation and documented experiments.

2.2 Explicitly out of scope

This paper will **not** recruit participants and will not conduct a user study. Consequently, it must not claim or experimentally evaluate:

- long-term human memorability;
- short-term human memorability;

- whether people naturally choose more secure visual concepts than passwords;
- whether users prefer the system to conventional authentication;
- human prompt-recall behaviour;
- human task-completion time; or
- usability for a particular user population.

The technical study may measure *representation reproducibility* under controlled prompt transformations, but this must never be presented as a substitute for human memorability evidence.

3 Key Security Principle: Image Complexity Is Not Secret Entropy

An AI-generated image may contain millions of pixels and visually complex details, but those pixels do not automatically provide persistent secret entropy. If the user remembers only the concept

$$C = \text{“cat wearing a hat”},$$

then the attacker’s relevant target is the concept C , not the random pixel-level state produced by the diffusion process.

The system must therefore avoid claims that image generation “amplifies” password entropy. Instead, security should be modelled through the probability distribution of semantic concepts and the set of variations accepted as equivalent.

Let S denote an enrolled semantic credential and let $d(S, S')$ be a semantic distance. For threshold τ , define the acceptance region

$$A_\tau(S) = \{S' : d(S, S') \leq \tau\}.$$

An attacker does not need to guess S exactly. The attack succeeds whenever a guess falls anywhere in $A_\tau(S)$. If $P(x)$ is the attacker’s semantic-guess distribution, the probability mass of the acceptance region is

$$P(A_\tau(S)) = \sum_{x \in A_\tau(S)} P(x).$$

Increasing τ can reduce false rejections but may increase attacker success. Quantifying this *security–reproducibility trade-off* is one of the central empirical and theoretical objectives of the paper.

4 System Model

4.1 Actors

The target system contains the following logical actors:

User / client	Creates and recreates the visual concept. The trusted client performs image generation and semantic extraction locally whenever feasible.
Authentication server	Maintains account state and decides whether authentication succeeds.
Privacy service	Optional independent service used for an OPRF, threshold OPRF, PSI, or related protocol. A multi-server construction may be used to prevent one compromised component from enabling offline semantic guessing.
Attacker	May submit online guesses, obtain a server database, use public prompt distributions, employ LLMs/VLMs/image generators, or attempt representation inversion and linkability attacks.

4.2 Privacy objective

The strongest target architecture should avoid transmitting the following plaintext material to the authentication server:

- the user’s natural-language secret description;
- generated images;
- plaintext semantic atoms;
- raw semantic embeddings; and
- unnecessarily precise similarity scores.

The desired server-visible authentication output is ideally restricted to the minimum information needed to enforce policy, such as an accept/reject result and protocol metadata.

4.3 Why local AI processing matters

If the user sends the secret prompt or generated image to a third-party image-generation API, that provider learns credential-related material. The research prototype should therefore prioritise locally deployable models so that the privacy properties being studied are not invalidated by an external inference service. Cloud models may be evaluated only as clearly labelled comparison points where the privacy implications are explicitly discussed.

5 Semantic Credential Representation

5.1 Structured semantic credential

The primary research representation should be a canonical set or graph of semantic atoms rather than a raw high-dimensional embedding alone. A generated image I is transformed into

$$S = \text{SemExtract}(I),$$

where S may contain:

- objects: `cat`, `bicycle`, `moon`;
- attributes: `black(cat)`, `yellow(helmet)`;
- counts: `count(cat)=1`;
- actions: `riding(cat,bicycle)`;
- spatial relations: `on(cat,bicycle)`; and
- scene-level concepts: `lunar-scene`.

The extractor should output a constrained machine-readable schema, such as deterministic JSON, before canonicalisation. The canonicalisation layer should normalise case, synonyms, attribute forms, relation direction, and model-specific surface text.

An illustrative credential could be

$$S = \{\text{cat}, \text{black-cat}, \text{yellow-helmet}, \text{bicycle}, \text{moon}, \text{riding}(\text{cat}, \text{bicycle})\}.$$

5.2 Weighted atoms

Not all atoms are equally discriminative. The system should therefore evaluate both unweighted and weighted matching. Let

$$S = \{(s_i, w_i)\}_{i=1}^n,$$

where w_i represents the security or stability weight of atom s_i . Common atoms may receive lower security weight, while rare combinations or relations may receive higher weight. Weights must be learned or estimated from a documented corpus rather than assigned merely by intuition.

5.3 Embedding baseline

A conventional vision-language embedding will be retained as a baseline:

$$z = E(I) \in \mathbb{R}^d.$$

Authentication can use cosine similarity

$$\text{sim}(z, z') = \frac{z \cdot z'}{\|z\| \|z'\|}.$$

The embedding baseline provides a useful accuracy reference, but raw embeddings should not be treated as privacy-preserving credentials. The project must explicitly test leakage, inversion, and linkability risks associated with storing or comparing them.

5.4 Text-only baseline

A reviewer can reasonably ask why the system generates an image at all if the user’s concept begins as text. The evaluation must therefore include a text-only baseline:

Prompt $\rightarrow$ semantic credential

versus the proposed path

Prompt $\rightarrow$ Image $\rightarrow$ semantic credential.

The paper should retain the image-generation stage only if experiments identify a measurable technical reason for doing so, such as robustness to paraphrase, semantic abstraction, or a security/privacy property. Human memorability cannot be used as the justification in this paper.

6 AI Components

The project should not define scientific novelty as simply choosing a particular AI model. Model choice is an experimental variable and an implementation dependency.

6.1 Image-generation model

The reference implementation should begin with a locally deployable, reproducible text-to-image model. A practical initial candidate is Stable Diffusion XL (SDXL), because it is widely supported and can be executed locally. The project may later add another open-weight generator to measure model dependence.

All experiments must record:

- exact model identifier and version/hash;
- inference library versions;

- sampler/scheduler;
- inference steps;
- guidance settings;
- resolution;
- random seed; and
- hardware/runtime configuration.

6.2 Semantic extraction models

At least three representation families should be considered:

1. **Structured detector/VLM pipeline.** Open-vocabulary detection plus attribute/relation extraction produces explicit semantic atoms. Grounding-DINO detection combined with a vision–language encoder is a useful baseline, particularly because closely related visual-semantic authentication work has used such a design.
2. **Constrained multimodal VLM.** A locally deployable VLM can be prompted to emit a fixed JSON scene representation containing objects, attributes, counts, actions, and relations. The model must run with deterministic or tightly controlled decoding settings and the output must pass schema validation.
3. **Dense embedding baseline.** CLIP/SigLIP-style image embeddings provide a conventional similarity baseline.

The final paper should select a primary extractor based on measured stability, discriminability, leakage, performance, and reproducibility rather than current popularity.

6.3 Model versioning

Authentication records must include non-secret identifiers for the semantic scheme and model version. The evaluation should measure enrolment with generator/extractor pair (G_1, E_1) and authentication under combinations such as (G_2, E_1) , (G_1, E_2) , and (G_2, E_2) . If semantic credentials are not stable across model upgrades, the paper must describe secure migration or explicitly state that re-enrolment is required.

7 Matching Function

For structured sets, a simple starting point is Jaccard similarity:

$$J(S, S') = \frac{|S \cap S'|}{|S \cup S'|}.$$

Authentication can require

$$J(S, S') \geq \tau_J.$$

A second candidate is weighted overlap:

$$W(S, S') = \frac{\sum_{s \in S \cap S'} w(s)}{\sum_{s \in S} w(s)},$$

with authentication when $W(S, S') \geq \tau_W$.

The exact function must be selected empirically. Importantly, the matching function used by the final system must have a feasible privacy-preserving implementation; a highly accurate plaintext metric is insufficient if it cannot be evaluated without revealing the credential.

8 Target Privacy-Preserving Protocol

8.1 Why ordinary encryption is insufficient

A naive design might encrypt the enrolled representation and then encrypt the authentication representation. Conventional semantically secure encryption does not preserve semantic distance, so in general

$$\text{Enc}(S) \approx \text{Enc}(S')$$

has no useful relationship to

$$S \approx S'.$$

The paper must therefore use a cryptographic protocol specifically designed for private comparison rather than claiming that encrypted vectors can be directly compared.

8.2 Primary protocol family: private threshold set matching

The primary design direction is a structured semantic set combined with privacy-preserving set matching. At a high level, the protocol should determine whether

$$|S \cap S'| \geq t$$

or whether a weighted equivalent exceeds a threshold, while disclosing as little additional information as possible.

Candidate primitives include:

- Oblivious Pseudorandom Functions (OPRFs);
- threshold OPRFs or a separately protected OPRF key;
- Private Set Intersection cardinality (PSI-CA);
- secure two-party computation; and
- thresholded private set matching that reveals only the accept/reject bit.

A single-server OPRF-derived token database may still become an offline dictionary oracle if an attacker obtains both the database and the server's OPRF key. The stronger design should therefore examine either a non-colluding two-service construction, threshold keying, or a hardware/key-isolation assumption. The final threat model must state this assumption explicitly.

8.3 Alternative protocol family: fuzzy extraction plus PAKE

A second research direction is to transform a noisy semantic representation into stable keying material and then use a modern password-authenticated key exchange. Conceptually:

$$\text{semantic representation} \rightarrow \text{fuzzy recovery} \rightarrow K \rightarrow \text{PAKE/OPAQUE}.$$

This is attractive because OPAQUE hides a password from the server during registration and authentication, but the semantic source may not have sufficient min-entropy for a conventional fuzzy extractor to be secure. Helper data could also leak structure or facilitate guessing. Therefore this construction should be treated as a candidate or baseline until its assumptions are demonstrated.

8.4 Alternative protocol family: encrypted vector similarity

For dense embeddings, private similarity can be evaluated with secure computation or homomorphic encryption. This provides a direct baseline for cosine/dot-product matching and allows comparison against the structured-set approach. However, encrypted computation does not by itself solve low semantic entropy or offline guessing after key compromise, so the paper must distinguish confidentiality of computation from credential-guessing security.

Algorithm 1 Canonical semantic credential extraction

Require: image I , extractor version v_E , canonicalisation version v_C

Ensure: canonical semantic credential S

- 1: $R \leftarrow \text{SemExtract}_{v_E}(I)$ $\triangleright$ structured machine-readable output
 - 2: verify R against the fixed semantic schema
 - 3: $S \leftarrow \text{Canon}_{v_C}(R)$
 - 4: remove unsupported/low-confidence atoms using fixed public rules
 - 5: normalise synonyms, relations, counts, and attribute forms
 - 6: sort S canonically
 - 7: **return** S
-

Algorithm 2 Enrolment

Require: user concept p , local generator G , extractor E , privacy protocol Π

Ensure: server-side protected credential record R_u

- 1: $I \leftarrow G(p; \rho)$ $\triangleright$ local generation with recorded experimental configuration
 - 2: $S \leftarrow \text{CANONICALSEMANTICCREDENTIAL}(I)$
 - 3: display local diagnostic representation only in research/debug mode
 - 4: $(R_u, \sigma_u) \leftarrow \Pi.\text{Register}(S)$
 - 5: store R_u plus non-secret scheme/model version metadata
 - 6: keep p , I , and plaintext S off the authentication server
 - 7: **return** enrolment success/failure
-

9 Protocol Algorithms

The following pseudocode defines the intended interfaces. It is a research specification, not a claim that the final cryptographic details have already been proved secure.

10 Threat Model

The evaluation should distinguish the following adversaries rather than treating all attacks as one category.

10.1 A1: Online semantic guesser

The attacker can submit authentication attempts to a target account and observe acceptance or rejection. The system may impose realistic rate limits. Evaluation should report success as a function of guess budget.

10.2 A2: Database-compromise attacker

The attacker obtains all stored authentication records but not necessarily separately protected cryptographic keys. The central privacy question is whether these records enable efficient offline testing or semantic reconstruction.

10.3 A3: Server/key compromise attacker

A stronger attacker obtains authentication-server state and some or all server-held cryptographic material. The paper must state precisely which secrets remain uncompromised under each construction. If the design depends on a non-colluding second service or hardware-isolated key, this must be explicit.

Algorithm 3 Authentication

Require: recreated concept p' , generator G' , extractor E' , protected record R_u

Ensure: authentication decision $b \in \{0, 1\}$

- 1: $I' \leftarrow G'(p'; \rho')$
 - 2: $S' \leftarrow \text{CANONICALSEMANTICCREDENTIAL}(I')$
 - 3: $b \leftarrow \Pi.\text{PrivateMatch}(S', R_u, \tau)$
 - 4: enforce rate limiting and replay/session protections
 - 5: **return** b
-

10.4 A4: AI-assisted attacker

The attacker can use LLMs, VLMs, text-to-image models, and empirical prompt distributions to generate likely semantic guesses and variations. This is a central attacker class rather than an edge case.

10.5 A5: Partial-information attacker

The attacker knows some semantic information about a target, for example hobbies, preferred objects, or k atoms from the enrolled concept. The experiments should quantify how attack success changes as partial knowledge increases.

10.6 A6: Representation-inversion attacker

The attacker attempts to infer objects, attributes, relations, prompts, or semantically equivalent concepts from stored records, embeddings, helper data, or protocol transcripts.

10.7 A7: Cross-service linker

Two services or compromised databases attempt to determine whether the same user reused the same semantic secret. Per-service domain separation and randomisation should be evaluated as privacy protections.

10.8 A8: Adversarial-input attacker

The attacker creates images or semantic descriptions designed to induce feature collisions, exploit the extractor, or enter a target user's acceptance region without reproducing the intended concept.

11 Research Questions

RQ1 – Semantic stability.

How consistently can independently generated images representing the same underlying concept be mapped to equivalent authentication representations across random seeds, paraphrases, styles, generators, and extractor versions?

RQ2 – Authentication separability.

How accurately can the system distinguish same-concept attempts from random and semantically close impostor concepts, and how does the acceptance threshold affect FAR, FRR, EER, ROC/AUC, and acceptance-region probability mass?

RQ3 – AI-assisted guessability.

How vulnerable are semantic credentials to dictionary, frequency-based, LLM-assisted, generator-assisted, and partial-information guessing attacks derived from realistic prompt distributions?

RQ4 – Template and protocol privacy.

What information can an attacker recover or validate from a stored record or observed transcript, and which protocol construction best reduces offline verification, representation inversion, and cross-service linkability?

RQ5 – Practicality.

What computational, communication, storage, and latency overhead is introduced by private semantic matching compared with plaintext semantic matching and conventional baselines?

RQ6 – Necessity of image generation.

Does the prompt-to-image-to-semantics pipeline provide measurable technical benefits over direct prompt-to-semantics authentication under the non-human evaluation used in this paper?

12 Experimental Methodology

12.1 Controlled semantic-concept corpus

The project should construct a controlled concept corpus with known semantic structure. Concepts should vary in object frequency, number of atoms, attribute specificity, relation complexity, and semantic similarity to neighbouring concepts. Because this corpus is researcher-generated, it must not be presented as evidence of real human choice behaviour.

For each concept, generate multiple images under controlled variations:

- different random seeds;
- prompt paraphrases created by documented deterministic rules or a separately logged model;
- changes in artistic style;
- changes in object position/orientation;
- alternative text-to-image model versions; and
- controlled omissions or substitutions of semantic atoms.

12.2 Real prompt-distribution corpus

To study guessability without recruiting participants, the project may use an existing public prompt corpus such as DiffusionDB. DiffusionDB contains millions of Stable Diffusion images and approximately 1.8 million unique prompts specified by real users. This dataset can support empirical frequency models for objects, attributes, relations, and prompt patterns.

Use of such a dataset does *not* justify claims about authentication-secret selection behaviour because its prompts were not collected as passwords. The paper should use it narrowly: as an empirical source for constructing plausible AI-assisted guessing dictionaries and estimating semantic frequency, with this limitation stated clearly.

12.3 Positive trials

Positive trials approximate technical reproduction, not human memory. For each base concept C :

1. generate enrolment image I_0 ;
2. independently generate m images intended to represent C under controlled transformations;
3. extract credentials $S_0, S_1, \dots, S_m$; and
4. measure similarity/matching success under each threshold and model configuration.

12.4 Negative trials

Negative trials should include increasingly difficult impostors:

1. random concepts;
2. concepts sharing one common object;
3. concepts sharing several attributes;
4. near-neighbour concepts differing in a critical relation or attribute;
5. frequency-ordered guesses from an empirical prompt model; and
6. LLM-generated semantic variants targeted at the enrolled concept class.

12.5 Model-drift trials

Enrol under (G_1, E_1) and authenticate under multiple pairs. Report the loss in positive matching and changes in false acceptance caused by model migration.

13 Evaluation Metrics

13.1 Authentication metrics

- False Acceptance Rate (FAR);
- False Rejection Rate (FRR);
- Equal Error Rate (EER);
- ROC curve and AUC;
- threshold-specific precision/recall where meaningful;
- representation stability across independent generations; and
- acceptance-region probability estimates.

13.2 Guessing-security metrics

- success@10, success@100, success@1,000, and larger feasible budgets;
- median/quantile guesses-to-success;
- fraction of accounts compromised by a fixed global dictionary;
- benefit of AI-assisted ordering over random ordering;
- effect of partial knowledge; and
- estimated probability mass of accepted semantic neighbours.

13.3 Privacy metrics

- offline guess-validation capability under each compromise model;
- semantic-atom recovery accuracy from stored records;
- prompt/concept inference accuracy where an inversion attack is feasible;
- cross-service linkage AUC/accuracy;
- protocol leakage: exact set overlap, similarity score, threshold bit, or other disclosed information; and
- sensitivity to compromise of one versus multiple protocol components.

13.4 Performance metrics

- image-generation latency;
- semantic-extraction latency;
- cryptographic protocol latency;
- end-to-end authentication latency;
- client/server CPU and GPU usage;
- memory usage;
- bandwidth per enrolment/authentication;
- server record size; and
- scalability with number of semantic atoms.

14 Baselines

At minimum, the evaluation should include:

1. **Plain embedding similarity:** raw CLIP/SigLIP-style embedding with cosine threshold. This is an accuracy/performance baseline, not a privacy-preserving design.
2. **Plain structured semantic matching:** canonical semantic atoms compared directly. This isolates the accuracy effect of the representation from cryptographic overhead.
3. **Visual-semantic authentication baseline:** reproduce, when feasible, the closest published visual-semantic authentication policy under its documented assumptions to demonstrate the novelty of the privacy-preserving contribution rather than claiming first use of visual semantics.
4. **Fuzzy recovery / fuzzy-extractor baseline:** evaluate whether a conventional noisy-secret construction is technically suitable and whether helper data produces unacceptable guessability or leakage.
5. **Privacy-preserving candidate:** OPRF/PSI, secure computation, or encrypted-similarity construction selected as the main protocol.
6. **Text-only semantic baseline:** remove image generation and compare prompt-derived semantics directly.

15 Security and Privacy Analysis

15.1 Offline verification

A central requirement is to identify exactly what an attacker can do after database compromise. A protected record is insufficient if it allows an attacker to transform arbitrary semantic guesses and compare them locally. The paper should distinguish:

- database-only compromise;
- database plus authentication-server key compromise;
- compromise of one server in a multi-server design; and
- compromise/collusion of all protocol services.

The claim should be no stronger than what the construction actually provides. If offline guessing is inevitable under full server compromise, the contribution may instead be resistance to precomputation, cost amplification, threshold-service separation, or reduced leakage. These must be quantified and stated precisely.

15.2 Representation leakage and inversion

The project should build explicit attacks attempting to predict semantic atoms from every stored representation considered as a baseline. For embeddings, train/evaluate simple classifiers or nearest-neighbour attacks. For helper data or protected tokens, test whether a dictionary permits efficient validation. Privacy must be measured rather than assumed from the absence of raw images.

15.3 Linkability

If the same semantic credential is enrolled at two services, service-specific salts/domain separation should make stored records unlinkable whenever the selected protocol supports this goal. Linkage attacks should compare same-secret/different-service and different-secret pairs under a documented adversary.

15.4 AI-assisted guessing

AI models reduce the cost of producing semantically coherent variants. The attack evaluation should therefore compare random guessing with:

- frequency-based semantic dictionaries;
- prompt templates mined from a public corpus;
- LLM-generated variations of common concepts;
- VLM-guided nearest-neighbour concepts; and
- partial-knowledge targeted guesses.

15.5 Adversarial semantic collisions

The extractor can become an attack surface. Experiments should test whether images with visibly different meanings can be engineered or searched to produce accepted semantic representations. At minimum, this should include black-box search over generator prompts and controlled semantic substitutions; gradient-based attacks may be added if the selected extractor permits them.

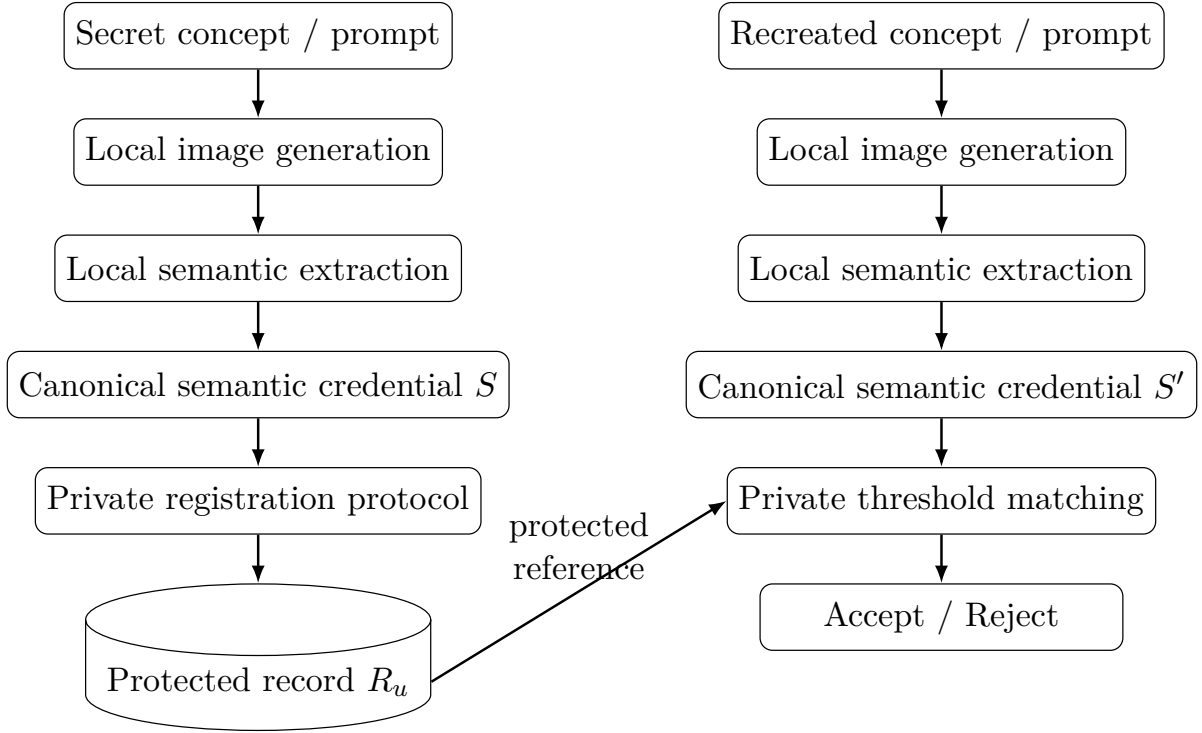


Figure 1: Target architecture. Prompt, image, and plaintext semantics remain client-side. The server stores a protected credential record and participates in a private matching protocol.

16 Prototype Architecture

The prototype should have separable modules:

1. local text-to-image generation;
2. semantic extraction;
3. canonicalisation/schema validation;
4. matching engine;
5. privacy protocol;
6. authentication server/API;
7. web client for demonstrator use;
8. experiment runner;
9. attack framework;
10. metrics/statistical analysis; and
11. reproducible configuration and artifact scripts.

The research code should make it possible to run the semantic and cryptographic experiments without the web UI. The UI is a demonstrator; the experiment pipeline is the scientific artifact.

17 Expected Contributions

A successful paper should aim for the following contributions, subject to experimental validation:

C1: Formalisation of semantic credentials. A model of semantic visual authentication as a noisy knowledge secret with an explicit acceptance region and a security–reproducibility trade-off.

C2: Privacy-preserving authentication protocol. A concrete protocol for matching semantic credentials while minimising disclosure of the secret and reducing the value of stored authentication records to an offline attacker. The exact security claim must match the selected construction and threat model.

C3: AI-assisted guessing and privacy analysis. A systematic evaluation of frequency-based, LLM/VLM-assisted, partial-information, inversion, linkability, and adversarial-semantic attacks.

C4: Implementation and reproducible evaluation. An end-to-end prototype plus an experiment framework evaluating semantic stability, authentication accuracy, privacy leakage, attack success, model drift, and cryptographic overhead.

18 Novelty Positioning

The paper must not claim to be the first system that authenticates visual semantics. Closely related 2026 work already proposes image-agnostic Visual Semantic Authentication using vision-language models, explicit semantic policies, approximate matching, and hash-based secret binding. That work should be treated as a central baseline and related-work anchor.

The intended novelty is instead the combination of:

- user-reproducible generative visual concepts as noisy semantic credentials;
- explicit modelling of acceptance-region guessability;
- privacy-preserving approximate matching rather than plaintext/hash-only semantic policy evaluation;
- analysis of database/server compromise and cross-service linkability;
- AI-assisted semantic guessing based on realistic prompt distributions; and
- an end-to-end private authentication prototype.

If implementation or evaluation does not substantiate these differences, the paper must narrow or change its claims rather than overstating novelty.

19 What Remains for Future Human-Subject Studies

A later study, subject to ethics review where required, could investigate:

- whether users can remember semantic visual credentials over days or months;
- how people naturally construct visual-secret concepts;
- whether the distribution of authentication secrets differs from ordinary generative-image prompts;
- whether system-generated guidance can increase security without harming memorability;
- authentication time and error behaviour with real participants;
- accessibility and user-interface requirements; and
- comparisons with passwords, passphrases, password managers, passkeys, and graphical-password systems from a human-factors perspective.

These questions are important, but they should not be mixed into the present paper’s empirical claims. The present project should establish whether the technical primitive is sufficiently secure, private, stable, and practical to justify such a study.

20 Ethical Considerations

The intended study avoids recruiting participants. Public datasets must be used according to their licences and documented research conditions. Even when public prompts are available, the project should minimise unnecessary retention of identifiers and should not attempt to deanonymise dataset contributors. Attack experiments should target synthetic/research accounts and locally controlled systems rather than third-party authentication services. Any newly discovered vulnerability affecting external software or services should be handled through responsible disclosure before publication.

The final PoPETs 2027 paper must use the mandatory ethical-considerations section from the official template and accurately report whether external ethics review was sought or required.

21 Open Science and Artifact Goals

The target artifact should enable reviewers/researchers to reproduce the principal figures and tables without manually operating the web interface. Subject to licences and storage constraints, release:

- source code;
- exact environment/dependency lock files;
- experiment configurations and random seeds;
- scripts to download public datasets and model weights rather than redistributing restricted content;
- generated non-sensitive test fixtures where licences permit;
- protocol benchmarks;
- attack scripts;
- analysis notebooks/scripts;
- raw/processed result tables needed to regenerate plots; and
- step-by-step artifact instructions.

The final paper must use the mandatory PoPETs 2027 Open Science section and must not promise release of materials that cannot legally or practically be distributed.

22 Use of AI in the Research and Manuscript

AI tools may be used for software assistance, language editing, brainstorming, or experimental components, but human authors retain responsibility for all scientific claims, references, code, experiments, and conclusions. Every bibliographic reference must be verified against the original source. Experimental prompts and model-assisted transformations that affect results must be logged and reproducible. The final PoPETs 2027 manuscript must contain the mandatory AI-use disclosure required by the venue.

23 Working Related-Work Anchors

The literature review should be completed systematically before claims of novelty are finalised. At minimum, the project should cover:

- graphical passwords and recognition/recall-based authentication;
- semantic and image-agnostic visual authentication, especially the 2026 VSA work;
- fuzzy extractors and secure sketches for noisy secrets;
- neural fuzzy extractors and privacy/security of learned authentication representations;
- OPRFs and threshold OPRFs;
- password-authenticated key exchange, including OPAQUE;
- PSI/PSI-cardinality and private threshold matching;
- homomorphic or secure-computation-based similarity matching;
- template protection, inversion, and linkability;
- AI-assisted password/credential guessing; and
- prompt datasets and prompt-distribution modelling, including DiffusionDB.

Reference hygiene. This research-direction document intentionally avoids pretending that an automatically generated bibliography is authoritative. Before the paper is written, all citations and BibTeX entries must be retrieved from and verified against primary sources or trusted bibliographic databases. PoPETs 2027 explicitly places responsibility for AI-assisted reference errors on the human authors.

24 Success Criteria for the Research Direction

The project should proceed toward a PoPETs submission only if the experiments support a coherent set of claims. A strong result would demonstrate that:

1. semantic credentials can be reproduced technically with a useful separation between intended and attacker concepts;
2. the chosen private-matching construction substantially reduces semantic leakage or offline-verification capability relative to plaintext/hash-only baselines;
3. the protocol has practical enough performance for an interactive authentication use case;
4. the security analysis honestly quantifies the cost of approximate matching and low/nonuniform semantic entropy;
5. the system remains distinguishable from existing visual-semantic authentication work through a concrete privacy contribution; and
6. all claims can be reproduced without a human-subject experiment.

A negative result in one dimension may still be publishable if it reveals a fundamental limitation, for example that realistic acceptance regions make semantic secrets too guessable, or that privacy-preserving matching imposes prohibitive overhead. The project should therefore optimise for scientifically defensible evidence rather than for proving the original idea correct.

25 Conclusion

This project investigates semantic authentication not as a claim that AI-generated images are inherently better passwords, but as a privacy problem involving noisy, nonuniform secrets. The proposed system converts independently generated images into canonical semantic credentials and uses a privacy-preserving protocol to test whether an authentication attempt falls inside the enrolled acceptance region. The research will quantify the resulting trade-offs among stability, false acceptance, false rejection, semantic guessability, stored-record privacy, linkability, and computational cost.

The principal technical challenge is to support approximate matching without turning the authentication database into a convenient semantic-guessing oracle. Structured semantic credentials combined with private set matching are the primary direction, while fuzzy-recovery/PAKE and encrypted-embedding comparison provide important alternatives and baselines. The project deliberately excludes human memorability and usability claims; those belong to future ethically reviewed user studies after the underlying privacy and security properties have been established.